

CYBERSECURITY MANAGEMENT PLAN

Adaptive Security and Zero Trust Operations Framework

AZTOF Version 2.0 | Research-Informed Edition

Prepared for:
XYZ Organization

Framework References: NIST CSF 2.0 | NIST SP 800-207 | CISA ZTMM 2.0 | MITRE ATT&CK | ISO/IEC 27001:2022

Classification: CONFIDENTIAL | Internal Use Only
Revision Date: April 2026

1. Introduction

Cybersecurity is not optional anymore. The numbers back that up. IBM reported the global average cost of a data breach hit \$4.88 million in 2024, and U.S. organizations averaged \$10.22 million per incident.

Healthcare breaches specifically ran \$9.77 million on average that same year. Cybercrime costs as a whole are projected to hit \$10.5 trillion annually by 2025.

The attack methods are not mysterious either. The human element (social engineering, errors, and credential misuse) shows up in about 60% of breaches per the 2025 Verizon DBIR, with stolen credentials at 22%, vulnerability exploitation at 20%, and phishing at 16% of initial access vectors. Ransomware showed up in 44% of breaches in the most recent Verizon DBIR, up from 32% the year before. Attackers are also getting faster. The median time from initial access to ransomware execution dropped to just five days in 2025.

Identity attacks account for nearly 90% of incident response cases, and 97% of those use nothing more than stolen or guessed passwords.

The frameworks we use to manage these risks have been updated too. NIST released CSF 2.0 in February 2024. The biggest change was adding a sixth function called Govern, which puts cybersecurity governance at the same level as any other enterprise risk. CISA updated their Zero Trust Maturity Model to version 2.0. The CISA Known Exploited Vulnerabilities catalog grew to 1,484 entries by end of 2025, a 20% jump from the year before.

This Cybersecurity Management Plan is built around the Adaptive Security and Zero Trust Operations Framework, or AZTOF. It pulls from NIST CSF 2.0, NIST SP 800-207, CISA ZTMM 2.0, and MITRE ATT&CK. Fayol's five management functions (Forecasting, Planning, Organizing, Coordinating, and Controlling) are used to manage each of the six AZTOF domains.

The six domains covered in this plan are:

- Identity and Access Governance (IAG)
- Threat Detection and Incident Response (TDIR)
- Data Protection and Privacy (DPP)
- Vulnerability and Configuration Management (VCM)
- Regulatory Compliance and Audit Readiness (RCAR)
- Security Culture and Workforce Resilience (SCWR)

2. Current Threat Landscape

Before building any plan, you need to understand what you are actually up against. Here is where things stand right now based on current data from IBM, Verizon, Sophos, CISA, and others.

2.1 Financial Impact

Key Data Point | IBM Cost of a Data Breach Report (2024 and 2025)

Global average breach cost: \$4.88M in 2024, dropped to \$4.44M in 2025 due to better AI-assisted detection. U.S. average: \$10.22M. Healthcare: \$9.77M in 2024. Organizations using AI and automation in security saved an average of \$1.9M per incident and cut breach response time by 80 days.

These are not theoretical numbers. For an organization handling healthcare data and financial analytics, a breach in either area puts you in the most expensive categories. The financial hit comes from multiple directions at once: remediation, legal fees, regulatory fines, notification costs, and reputational damage. All of that adds up fast.

2.2 Primary Attack Vectors

Key Data Point | Verizon DBIR and IBM X-Force 2025

Human element (social engineering, errors, credential misuse): around 60% of breaches. Identity attacks using password spray or brute force: 97%. Ransomware in 44% of breaches (up from 32%). Third-party and supply chain involvement: 30% of breaches, doubled from 15%. Stolen credentials: 22% of initial access. Exploitation of vulnerabilities: 20% of initial access. Phishing: 16% of initial access.

The identity attack numbers alone make MFA the single most important control you can put in place. If 97% of identity attacks rely on stolen or guessed passwords, then MFA stops almost all of them. AI-generated phishing content now makes up more than 80% of observed social engineering activity. The old advice of just look for typos and weird formatting is not enough anymore. The phishing emails look real now.

2.3 Vulnerability Landscape

Key Data Point | CISA KEV Catalog and Cyble Analysis (2025)

CISA KEV catalog reached 1,484 entries by end of 2025, a 20% increase. CISA added 245 new entries during 2025, a 30% jump from the 185 added in 2024. 24 of those 2025 additions are confirmed ransomware-linked. Over 900 KEV entries showed first evidence of exploitation during 2025. Top exploited weakness types: OS Command Injection, Deserialization, Path Traversal, and Use-After-Free.

The KEV catalog is the clearest signal available on what attackers are actually using right now. In 2025 CISA added 245 vulnerabilities, the fastest pace since the catalog launched. 24 of those are directly tied to ransomware groups. The practical takeaway is that vulnerability management has to be intelligence-driven and continuous. You cannot just run a scan once a month and call it done.

2.4 Workforce and Human Risk

Deepfake attacks are growing fast. The percentage of security professionals who say they are not prepared for deepfake attacks jumped from 3% to 21% among managers between 2024 and 2025. For C-suite leaders it went from 6% to 28%. IBM's 2025 Cost of a Data Breach Report found that attackers used AI in 16% of breaches, most often for phishing campaigns and deepfake impersonation. On top of that, 40.2% of

ransomware victims in 2025 said a lack of cybersecurity expertise contributed to their breach. Security awareness training is not just a checkbox. It directly reduces breach risk.

3. AZTOF Governance Framework

3.1 Framework Foundations

AZTOF is built on four current frameworks. Each one was picked because it addresses something specific and relevant.

NIST Cybersecurity Framework 2.0 (Released February 26, 2024)

This is the most significant update to the CSF since it was first published in 2014. The big change is the new Govern function. It sits at the center of the framework and connects to all five other functions. That placement is intentional. It signals that governance is not a supporting activity. It is the core. CSF 2.0 also expanded scope so it applies to all organizations, not just critical infrastructure. It added guidance on supply chain risk, secure software development, and DevSecOps. AZTOF maps all six of its domains to the CSF 2.0 functions.

NIST SP 800-207 (Zero Trust Architecture)

NIST SP 800-207 defines Zero Trust through seven tenets. The core idea is that no user, device, or network is trusted by default. Access is granted per session based on dynamic policy and continuous verification. The NCCoE published a companion guide in June 2025 (NIST SP 1800-35) that walks through 19 real ZTA implementations across cloud and on-premises environments. It proves ZTA is practical, not just theoretical. AZTOF's Identity and Access Governance domain is built directly on these principles.

CISA Zero Trust Maturity Model 2.0

CISA's ZTMM 2.0 breaks Zero Trust down into five pillars: Identity, Devices, Networks, Applications and Workloads, and Data. There are also three cross-cutting capabilities: Visibility and Analytics, Automation and Orchestration, and Governance. The model defines four maturity stages: Traditional, Initial, Advanced, and Optimal. AZTOF uses the ZTMM 2.0 as the Zero Trust maturity assessment tool. The target is reaching the Advanced stage across all five pillars within 36 months.

MITRE ATT&CK Enterprise Framework

MITRE ATT&CK is a catalog of real adversary tactics, techniques, and procedures based on observed attacks. AZTOF uses it for threat modeling, detection gap analysis, and red and purple team exercise design. Mapping SIEM detection rules to ATT&CK techniques gives a structured way to find and close blind spots in detection coverage.

3.2 AZTOF Domain Descriptions

Domain 1: Identity and Access Governance (IAG)

IAG covers who and what can access systems, data, and resources. Given that 97% of identity attacks use stolen or guessed passwords and identity weaknesses show up in nearly 90% of IR investigations, this is the highest-impact domain in the framework. IAG enforces MFA for everyone, implements privileged access management, pushes toward phishing-resistant FIDO2 authentication for high-privilege roles, and manages the full identity lifecycle from hire to termination.

Domain 2: Threat Detection and Incident Response (TDIR)

TDIR covers the ability to detect attacks through SIEM and EDR tools mapped to MITRE ATT&CK, triage and validate alerts through a SOC function, contain and eradicate threats, and recover in a controlled and documented way. With ransomware executing in a median of five days from initial access, detection speed directly determines how bad the outcome is.

Domain 3: Data Protection and Privacy (DPP)

DPP covers the full lifecycle of sensitive data including classification, handling, encryption, retention, and disposal. It also covers compliance with HIPAA and GDPR. For an organization processing healthcare and financial data, these controls are both a contractual requirement and a regulatory one.

Domain 4: Vulnerability and Configuration Management (VCM)

VCM establishes a process for finding, prioritizing, and fixing vulnerabilities across the technology environment. The CISA KEV catalog is the primary prioritization input. VCM also maintains secure baseline configurations using CIS Benchmarks and extends those standards into CI/CD pipelines through DevSecOps.

Domain 5: Regulatory Compliance and Audit Readiness (RCAR)

RCAR keeps the organization compliant with applicable regulations and ready for audits at all times. A GRC platform and continuous controls monitoring automate evidence collection so audit readiness is a steady state, not a panic sprint every year. Applicable frameworks include HIPAA, GDPR, CCPA, SOC 2 Type II, and NIST CSF 2.0.

Domain 6: Security Culture and Workforce Resilience (SCWR)

SCWR targets the human factor, which shows up in about 60% of all breaches per the 2025 Verizon DBIR. Role-specific training, monthly phishing simulations calibrated to current AI-enhanced techniques, and targeted follow-up for employees who show risky behavior are all part of this domain. The data is clear: 40.2% of 2025 ransomware victims cited insufficient cybersecurity expertise as a contributing factor. Better trained people means fewer breaches.

4. Fayol's Management Functions Applied

Each AZTOF domain is managed through Fayol's five functions. This keeps cybersecurity from being a collection of disconnected technical tasks and turns it into a managed organizational program with clear ownership and measurable outcomes.

4.1 Identity and Access Governance (IAG)

Threat context: Identity attacks account for 65% of initial access in IR investigations. Modern MFA prevents more than 99% of identity-based attacks. Despite that, cloud identities are found to be over-permissioned in 99% of large-sample audits. The least-privilege gap is real and widespread.

Forecasting: Quarterly threat intelligence reviews will track emerging identity attack methods including adversary-in-the-middle phishing, SIM swapping, and session token hijacking. The organization will subscribe to CISA advisories and relevant ISAC feeds for early warning. Annual MFA coverage audits will measure the gap between current enrollment and the 100% target across all user types including employees, contractors, service accounts, and partners. CISA ZTMM 2.0 Identity pillar maturity assessments will define the roadmap to the next stage.

Planning: An annual Identity Security Roadmap will prioritize: getting MFA to 100% across all user types; migrating high-privilege accounts to FIDO2 phishing-resistant authenticators per the CISA Phishing-Resistant Authenticator Playbook; deploying a PAM solution covering all privileged accounts; and formalizing RBAC matrices with documented access request, approval, and review workflows. Conditional access policies will enforce device compliance as a condition of network access per NIST SP 800-207.

Organizing: An Identity Governance team will be established in the IT Security function. It will include an IAM Engineer who handles directory services, provisioning, and MFA platform management, and a Privileged Access Administrator who runs the PAM tool and monitors privileged sessions. RACI matrices will define ownership for every identity governance process. A cloud-based IAM platform and PAM solution will be selected and deployed on a phased schedule with defined milestones.

Coordinating: IAG activities will be formally tied into HR's joiner, mover, and leaver processes with automated triggers for provisioning, access changes, and deprovisioning. The target is under four hours from termination notification to account deactivation. Legal and Procurement will set contractual identity standards for vendors so third-party access stays least-privilege and gets reviewed regularly. A quarterly Identity Review Board with IT Security, HR, Legal, and Business Unit leads will govern access exceptions and manage the privileged account population.

Controlling: Monthly access certification campaigns will require managers to confirm their direct reports' permissions through the IAM platform. Automated controls will flag dormant accounts over 30 days, stale MFA registrations, and over-permissioned service accounts. Key KPIs reported monthly to the CISO: MFA enrollment rate (target: 100%); phishing-resistant MFA for privileged roles (target: 80% within 18 months); average time to deprovision terminated employees (target: under 4 hours); privileged account count (target: 40% reduction from baseline within 12 months). Annual third-party identity pen testing will validate control effectiveness.

4.2 Threat Detection and Incident Response (TDIR)

Threat context: Ransomware executed in a median five days in 2025, down from nine days in 2023. Organizations using AI and automation in security cut response time by 80 days and saved \$1.9M per incident on average. The faster you detect, the less damage you take.

Forecasting: The organization will run a Cyber Threat Intelligence program that continuously pulls data from commercial threat feeds, CISA KEV updates, ISAC advisories, and MITRE ATT&CK reports. Forecasting will map current TTPs to the organization's technology stack and identify detection gaps by technique. The Initial Access, Credential Access, and Impact tactic clusters from ATT&CK are the priority targets given their prevalence in healthcare and financial sector breaches. Annual tabletop exercises and a red/purple team exercise every 18 months will test assumptions and detection coverage.

Planning: A comprehensive Incident Response Plan will be developed, reviewed annually, and exercised twice a year. The IRP defines five severity levels (P1 through P5), escalation paths, communication templates, regulatory notification timelines (HIPAA 60-day and GDPR 72-hour requirements), and recovery time objectives per system tier. A dedicated ransomware playbook will address double-extortion scenarios including data exfiltration before encryption, negotiation decision criteria, and backup-based recovery. AI-driven detection will be built into the SIEM platform to reduce mean time to detect.

Organizing: A virtual SOC will be staffed by in-house Tier 1 analysts with a contracted MDR partner covering Tier 2 and Tier 3 escalations and 24/7 monitoring. A pre-constituted Incident Response Team will have defined roles: Incident Commander, Technical Lead, Forensics Analyst, Communications Lead, and Legal/Compliance Liaison. All IRT members will hold current IR certifications and participate in at least two exercises per year. On-call schedules, out-of-band communication channels, and escalation contact trees will be documented, tested, and updated quarterly.

Coordinating: TDIR will be coordinated with Business Continuity Management to make sure the IRP and disaster recovery plans align and that RTO and RPO targets are consistent. Pre-established protocols with the FBI Cyber Division (IC3), CISA, and external cybersecurity legal counsel will be in place before an incident happens. SIEM ticketing will integrate with IT Operations workflows so remediation actions move through the change management process. Post-incident communications will be reviewed by Legal before any external disclosure.

Controlling: A monthly SOC Metrics Dashboard will track: MTTD by severity (P1 target: under 30 minutes); MTTR by severity (P1 target: under 4 hours); false positive rate (target: under 20%); and incident recurrence rate (target: zero for closed incidents). Mandatory Post-Incident Reviews will be completed within 5 business days for all P1 and P2 incidents. Lessons learned get tracked to remediation in the GRC platform. Semi-annual IRP exercises will include at least one unannounced drill per year.

4.3 Data Protection and Privacy (DPP)

Threat context: Most ransomware attacks now steal data before encrypting it. Having a backup does not fully protect you anymore. Third-party involvement in breaches doubled from 15% to 30% in the most recent Verizon DBIR. Healthcare data breaches averaged \$9.77 million in 2024, the highest of any industry.

Forecasting: Annual data discovery and classification exercises will maintain a current inventory of all sensitive data including PHI, PII, financial data, and intellectual property, and will map data flows across cloud environments, SaaS platforms, and third-party processors. The regulatory environment will be monitored with compliance impact assessments completed 180 days in advance of effective dates. Data Protection Impact Assessments will be triggered automatically for any new system or process that involves sensitive data.

Planning: A four-tier Data Classification Policy will be formalized: Public, Internal, Confidential, and Restricted. Each tier will have documented handling requirements including encryption standards (AES-256 at rest and TLS 1.3 in transit for Confidential and Restricted tiers), retention schedules aligned to HIPAA and GDPR requirements, and certified destruction procedures. DLP policies will enforce classification-based controls automatically across endpoints, cloud storage, and email. Vendor data processing agreements and Business Associate Agreements will be reviewed on a defined schedule.

Organizing: A Data Protection Officer will be designated to own the DPP program with data stewards embedded in each business unit. Data stewards are accountable for enforcing classification policies and reporting violations. The IT Security team manages the DLP tooling. Policy configuration is owned by the DPO. Third-party data processor onboarding requires a mandatory security assessment before contract execution, managed jointly by Procurement, Legal, and IT Security.

Coordinating: DPP will coordinate with Legal for BAA and GDPR DPA management and breach notification obligations. The Privacy program works with Procurement so vendor risk assessments happen before any new data sharing arrangement goes live. Data breach response procedures in DPP are directly integrated with the TDIR IRP so incident responders always have current data classification information when assessing notification timelines.

Controlling: Monthly DLP exception reports will be reviewed by the DPO with escalation to the CISO for any pattern of repeated violations or Restricted data policy exceptions. Annual privacy audits will check encryption coverage, retention schedule compliance, third-party processor attestations, and DPIA completion rates. KPIs: percentage of sensitive data systems with verified encryption (target: 100%); DLP exception rate trend (target: declining quarter over quarter); third-party processor annual attestation completion rate (target: 100%); DPIA completion rate for applicable new systems (target: 100%).

4.4 Vulnerability and Configuration Management (VCM)

Threat context: CISA added 245 new KEV entries in 2025, a 30% acceleration, and 24 of those are confirmed ransomware-linked. Exploitation of vulnerabilities was the most common initial infection vector at 33% in IR investigations. The Sophos 2025 State of Ransomware report confirmed 32% of ransomware incidents started with an exploited vulnerability.

Forecasting: The VCM program will maintain continuous intelligence integration with the CISA KEV catalog (checked multiple times per week), the NIST NVD, vendor security advisories, and commercial threat feeds. A Configuration Management Database will track all assets and automatically cross-reference new KEV entries against the organization's technology stack. Any newly cataloged exploited vulnerability affecting a deployed asset triggers an immediate alert to the responsible system owner. The industry benchmark for KEV remediation SLA is 48 hours, and that is the target.

Planning: A Vulnerability Management Policy will define: scanning cadences (weekly for internet-facing and high-criticality systems, monthly for internal systems); severity-based remediation SLAs (Critical CVSS 9.0 and above: 15 days; High CVSS 7.0 to 8.9: 30 days; KEV entries regardless of CVSS: 48 hours); exception processes requiring documented compensating controls and CISO approval; and re-scan requirements after remediation. A Secure Configuration Management Plan will establish hardening baselines from CIS Benchmarks for all operating systems, cloud workloads, containers, and network devices.

Organizing: An IT Security Engineer will own the VCM program. System owners are accountable for remediating findings within defined SLAs. Automated scanning tools including an enterprise vulnerability scanner, CSPM tooling, and container image scanning will be deployed across all assets. A monthly Configuration Compliance Working Group will review drift reports and assign remediation owners. DevSecOps integration extends secure configuration standards and dependency scanning into CI/CD pipelines, consistent with CSF 2.0's emphasis on secure software supply chain management.

Coordinating: VCM integrates with the IT Change Management process so patches deploy through controlled change windows. Emergency change procedures are pre-defined for KEV and critical actively exploited vulnerabilities, allowing accelerated deployment with appropriate approvals. VCM coordinates with TDIR so that any KEV-listed vulnerability affecting the environment triggers threat hunting in the vSOC to check for indicators of compromise concurrently with patching.

Controlling: Monthly vulnerability dashboards will report open findings by severity and SLA status, patch coverage by asset tier, and KEV remediation compliance. Configuration compliance scans run weekly with automated reports to system owners for any drift. Annual third-party penetration testing targets the vulnerability classes most common in the CISA KEV catalog and the organization's own scan history. KPIs: KEV 48-hour remediation compliance (target: 100%); Critical SLA compliance (target: over 95%); assets with verified baseline configuration (target: over 98%); open critical findings older than 15 days (target: zero).

4.5 Regulatory Compliance and Audit Readiness (RCAR)

Threat context: Regulatory enforcement is getting more aggressive alongside rising breach frequency. GDPR fines hit record levels in recent years. HIPAA enforcement continues to follow major healthcare breaches. Cyber insurance underwriters now require demonstrated compliance with established frameworks as a condition of coverage. CSF 2.0's Govern function makes compliance a top-level organizational responsibility, not something buried in IT.

Forecasting: RCAR forecasting monitors the regulatory environment for XYZ Organization: HIPAA for healthcare data, GDPR and CCPA for personal data, SOC 2 Type II for cloud service trust, and NIST CSF 2.0 which is increasingly referenced by enterprise customers and cyber insurers. A regulatory horizon calendar tracks proposed rules, effective dates, and projected compliance gaps, with legal counsel engaged for regulatory changes that have 12 to 18 months of lead time. Cyber insurance renewal cycles serve as structured forcing functions to assess and demonstrate compliance posture improvements.

Planning: An annual Compliance Work Plan will map all applicable regulatory requirements to specific AZTOF controls, assign control owners, and schedule internal audits and external assessments. Continuous Controls Monitoring through a GRC platform will automate evidence collection for SOC 2 and HIPAA controls. That turns audit readiness into a steady state instead of a last-minute scramble. The control library aligns to NIST CSF 2.0, which cross-references ISO 27001, CIS Controls, and the HIPAA Security Rule so the organization gets multi-framework coverage efficiently.

Organizing: A Compliance and Risk Manager will be established in the IT Security function with dotted-line reporting to Legal. This role owns the Risk Register, coordinates internal audits, manages relationships with external auditors, and handles regulatory inquiries. The GRC platform is the system of record for policies, controls, evidence, risk register entries, and audit findings. All control owners have access through automated workflows with evidence collection reminders.

Coordinating: RCAR is embedded across all business functions. Finance reflects cybersecurity compliance obligations in budgeting and cyber insurance requirements. Procurement enforces third-party compliance requirements as a contract condition. The Compliance and Risk Manager presents the compliance posture to executive leadership and the Board quarterly, consistent with CSF 2.0's Govern function requirement for leadership engagement in cybersecurity risk decisions.

Controlling: Quarterly compliance posture reports will cover: control effectiveness scores by framework; open audit findings with aging; corrective action plan status; and regulatory obligation coverage percentages. Any non-compliance triggers a formal corrective action plan with named executive accountability and a defined remediation timeline. KPIs: percentage of controls with current verified evidence (target: 100%); internal audit finding close rate within timelines (target: over 90%); SOC 2 Type II opinion outcome (target: unqualified); HIPAA risk assessment currency (target: completed annually within 12 months of prior assessment).

4.6 Security Culture and Workforce Resilience (SCWR)

Threat context: About 60% of breaches involve a human element per the 2025 Verizon DBIR, including social engineering, errors, and credential misuse. AI-generated phishing now makes up more than 80% of observed social engineering activity. Deepfake attacks are the fastest-growing category of threats that security teams say they are not ready for. And 40.2% of 2025 ransomware victims said insufficient cybersecurity expertise contributed to their breach. Training your people is breach prevention.

Forecasting: SCWR forecasting uses phishing simulation failure rates segmented by department, role, and attack type, along with security incident data especially social engineering cases, and threat intelligence on AI-enhanced techniques. Annual security culture surveys establish a qualitative baseline of employee knowledge gaps and reporting behavior. Phishing simulations will incorporate AI-enhanced lures including deepfake voice phishing scenarios for high-risk roles like finance and executive assistants to establish a realistic baseline of organizational susceptibility.

Planning: A Security Awareness and Training Program will deliver role-differentiated content across four tracks: General Awareness for all employees covering phishing, credential hygiene, physical security, and incident reporting on a quarterly basis; High-Risk Roles for Finance, HR, and Executive Assistants with

monthly simulations and bi-annual in-person workshops on BEC, deepfake vishing, and wire fraud scenarios; Technical Security for IT and Development staff on secure coding, OWASP Top 10, cloud configuration, and incident handling; and a Leadership Track for managers and executives on governance, breach decision-making, and regulatory obligations. Simulation templates refresh quarterly to keep pace with evolving attacker techniques.

Organizing: The CISO owns the SCWR domain with day-to-day management handled by a Security Awareness Manager. A security champions program recruits volunteers from each business unit who serve as peer advocates and first-line reporters of suspicious activity. The security awareness platform automates phishing simulation deployment, tracks completion by department, delivers immediate remedial training to employees who fail simulations, and gives managers department-level risk dashboards.

Coordinating: SCWR coordinates with HR to integrate security orientation into the new employee onboarding process with Day 1 completion of baseline training as a condition of system access. Training completion rates are tracked as a compliance requirement in HR systems. Security behavior is incorporated into performance management frameworks. Legal ensures data handling and incident reporting training reflects actual privacy and breach notification obligations. Business unit leaders are formal program sponsors accountable for their teams' completion rates.

Controlling: Program effectiveness is tracked through a quarterly Security Culture Scorecard: phishing simulation click rate (target: under 5% organization-wide; under 10% for new employees in their first 90 days); training completion rate (target: 100% by role-assigned deadline); self-reported security incident rate (target: increasing, because it shows people are actually reporting); post-training knowledge assessment pass rate (target: over 85%); and security champion engagement rate (target: over 90% completing supplemental training quarterly). The CISO presents the scorecard to executive leadership quarterly with year-over-year trending. Departments consistently above the 5% phishing click rate get targeted intervention within 30 days.

5. AZTOF Governance Summary Matrix

This table summarizes Fayol's five management functions across all six AZTOF domains. It is a quick-reference tool for the CISO, executive leadership, and auditors.

Domain	Forecasting	Planning	Organizing	Coordinating	Controlling
Identity and Access Governance	Quarterly identity threat reviews; CISA ZTMM Identity pillar assessment; MFA coverage gap analysis	Annual Identity Security Roadmap; FIDO2 for privileged roles; RBAC matrices with access workflows	IAM Engineer and Privileged Access Admin; PAM tool deployment; SSO and lifecycle platform	HR joiner/mover/leaver integration; under 4 hour deprovisioning SLA; quarterly Identity Review Board	Monthly access certifications; dormant account flagging; 100% MFA target; monthly CISO reporting
Threat Detection and Incident Response	CTI program with CISA KEV and MITRE ATT&CK; annual tabletop; 18-month red/purple team exercises	IRP with P1 through P5 severity levels; ransomware double-extortion playbook; HIPAA 60-day and GDPR 72-hour notification	vSOC with 24/7 MDR partner; pre-constituted IRT with defined roles; out-of-band comms tested quarterly	Integrated with BCM; pre-established FBI IC3, CISA, and legal counsel protocols; SIEM to ITSM ticketing	P1 MTTD under 30 min; P1 MTTR under 4 hours; mandatory PIRs within 5 days; semi-annual IRP exercises
Data Protection and Privacy	Annual data discovery and classification; regulatory horizon calendar 180+ days ahead	4-tier classification policy; AES-256 and TLS 1.3 standards; DPIA process; DPA and BAA schedule	DPO and embedded business unit data stewards; DLP tooling; vendor security assessment before onboarding	Legal for BAA and GDPR obligations; Procurement for vendor risk; integrated with TDIR IRP	Monthly DLP exception review; 100% encryption target; annual privacy audits; third-party attestation tracking
Vulnerability and Configuration Mgmt	CISA KEV catalog monitoring multiple times per week; CMDB cross-referencing; NVD and vendor advisory feeds	KEV 48-hour SLA; Critical 15-day SLA; CIS Benchmark baselines; DevSecOps scanning in CI/CD pipelines	IT Security Engineer as program owner; CSPM and container scanning; monthly Config Compliance Working Group	Change Management integration; emergency change procedure for KEV; threat hunting concurrent with patching	100% KEV compliance target; monthly dashboards; weekly config drift reports; annual penetration test
Regulatory Compliance and Audit Readiness	Regulatory horizon calendar; 12 to 18 month legal counsel engagement; cyber insurance alignment	Annual Compliance Work Plan mapped to NIST CSF 2.0; CCM platform; multi-framework control library	Compliance and Risk Manager; GRC platform as system of record; automated evidence workflows	Embedded across Finance, Procurement, and Legal; quarterly Board compliance posture briefing	100% controls evidenced; over 90% audit finding close rate; unqualified SOC 2 opinion target; annual HIPAA RA

Domain	Forecasting	Planning	Organizing	Coordinating	Controlling
Security Culture and Workforce Resilience	AI-enhanced phishing simulation baselines; annual culture survey; social engineering trend monitoring	4-track SATP (General, High-Risk, Technical, Leadership); AI lure template refresh quarterly	Security Awareness Manager; business unit security champions program; security awareness platform	Day 1 onboarding integration; manager accountability for team completion; legal alignment on reporting	Under 5% org-wide phishing click rate; 100% training completion; quarterly Security Culture Scorecard to exec

6. Conclusion

The threat environment is not slowing down. Global average breach costs hit \$4.88 million in 2024. Ransomware showed up in 44% of breaches. Attackers are deploying ransomware in a median of five days from initial access. CISA added 245 new confirmed-exploited vulnerabilities to their catalog in 2025 alone. AI now drives over 80% of phishing campaigns. These are not projections. They are current data points.

AZTOF is built to address this environment directly. It pulls from NIST CSF 2.0 including the new Govern function, CISA's Zero Trust Maturity Model 2.0, NIST SP 800-207, and MITRE ATT&CK. The six governance domains cover identity, detection and response, data protection, vulnerability management, compliance, and workforce resilience. Fayol's management functions make sure each domain is run with clear ownership, defined activities, and measurable outcomes.

The IBM finding that AI-assisted security programs reduce response time by 80 days and save \$1.9 million per incident is worth noting. That is not just from buying better tools. It comes from having the organizational capability to deploy, integrate, and act on those tools. That is what this plan is designed to build.

This plan gets reviewed annually. The CISO leads the review with executive leadership and the Board in line with CSF 2.0's Govern function requirements. As the threat environment changes, as regulations update, and as the organization grows, the specific activities within each AZTOF domain get updated to match. The framework stays stable. The activities inside it stay current.

END OF DOCUMENT

AZTOF CMP v2.0 | XYZ Organization | April 2026 | CONFIDENTIAL

7. References and Sources

The following sources informed the threat data, framework references, and recommended practices in this plan:

- National Institute of Standards and Technology (NIST). Cybersecurity Framework 2.0. February 26, 2024. <https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final>
- NIST. Special Publication 800-207: Zero Trust Architecture. 2020.
- NIST NCCoE. SP 1800-35: Implementing a Zero Trust Architecture. June 2025. <https://pages.nist.gov/zero-trust-architecture/>
- CISA. Zero Trust Maturity Model v2.0. April 2023. <https://www.cisa.gov/resources-tools/resources/zero-trust-maturity-model>
- CISA. Known Exploited Vulnerabilities (KEV) Catalog. Updated continuously. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- CISA. Zero Trust Architecture Implementation Report. January 29, 2025.
- IBM Security. Cost of a Data Breach Report 2024. 2024.
- Verizon. 2025 Data Breach Investigations Report (DBIR). 2025.
- Sophos. State of Ransomware 2025. 2025.
- IBM X-Force. Threat Intelligence Index 2025. 2025.
- Cyble. 2025 CISA KEV Catalog Analysis. January 2026. <https://cyble.com/blog/cisa-kev-2025-exploited-vulnerabilities-growth/>
- KnowBe4. 2025 Phishing by Industry Benchmarking Report. 2025.
- Microsoft. Digital Defense Report 2025. October 2025.
- MITRE ATT&CK. Enterprise Matrix (current). <https://attack.mitre.org/matrices/enterprise/>

- ISO/IEC 27001:2022. Information Security Management Systems. 2022.
- OMB Memorandum M-22-09. Moving the U.S. Government Toward Zero Trust Cybersecurity Principles. January 26, 2022.